PR PR Campania FSE+ 2021-2027 Priorità 2
Obiettivo Specifico ESO4.6 Azione 2.f.11

FONDAZIONE DI ISTRUZIONE TECNICA SUPERIORE (ITS) – PERCORSI FORMATIVI
ICT CAMPUS
D.G.R. n. 272 del 22/06/2021 – D.G.R. n. 404 del 22/09/2021
D.D. n. 505 dell'1/10/2021 - D.D. n. 534 del 12/06/2023

Priorità 2 – Obiettivo Specifico ESO4.6 – Azione 2.f.11
Codice Ufficio 39 - Codice CUP B81I23000350006
Titolo progetto "Fondazione ITS "ICT CAMPUS - ITS ACADEMY""
Codice SURF 21065AP000000020

"Tecnico superiore per le architetture e le infrastrutture per i sistemi di comunicazione"

PERCORSO NETWORK & IOT SPECIALIST

PROGRAMMA DEL CORSO

Modulo: VA/PT

Docente: GIUSEPPE CAPASSO

Programma del Corso: Vulnerability Assessment e Penetration Testing

1. Descrizione del Corso

Il presente corso di livello avanzato è progettato per fornire competenze pratiche e operative nel campo della sicurezza offensiva (Offensive Security). Attraverso un approccio strettamente laboratoriale (hands-on), il percorso formativo guida gli studenti nell'analisi, identificazione e sfruttamento delle vulnerabilità informatiche attraverso tre macro-aree fondamentali:

- la sicurezza delle applicazioni (web e di sistema),
- la sicurezza delle infrastrutture di rete
- la sicurezza del software a basso livello.

Le simulazioni di attacco verranno condotte sia in ambienti locali isolati sia su piattaforme di addestramento professionali, garantendo un'esperienza immersiva e allineata alle attuali sfide del settore cyber.

2. Obiettivi Formativi

Al termine del percorso didattico, gli studenti saranno in grado di:

- **Analizzare e compromettere applicazioni vulnerabili:** Sfruttare le principali vulnerabilità web e di sistema su ambienti simulati (DVWA, OWASP Nodegoat) e misurarsi con scenari realistici su piattaforme di training ufficiali (HackTheBox, TryHackMe).
- **Eseguire attacchi infrastrutturali:** Comprendere le debolezze dei protocolli di rete ed eseguire attacchi di tipo Man-in-the-Middle (MitM) a livello di datalink e di rete (Layer 2 / Layer 3), con applicazioni pratiche su apparati fisici di classe enterprise (Cisco).
- **Sviluppare exploit a basso livello:** Comprendere l'architettura della memoria di un sistema informatico ed eseguire attacchi di corruzione della memoria (Binary Exploitation), con particolare focus sulla scrittura di exploit per vulnerabilità di Buffer Overflow su architettura x86.

---

3. Syllabus del Corso

FASE I: Sicurezza delle Applicazioni

Modulo 1: Metodologia e Ambienti Simulati Locali

- Introduzione agli ambienti di test isolati: configurazione e deploy di container vulnerabili.
- **Web Application Security:** Sfruttamento pratico delle vulnerabilità della OWASP Top 10 utilizzando **DVWA (Damn Vulnerable Web App)** e **OWASP Nodegoat**.
- Injections (SQLi, Command Injection), Cross-Site Scripting (XSS), Broken Authentication.
- **System Security:** Fase di enumeration e compromissione di servizi di rete mal configurati utilizzando **Metasploitable** come target locale.

Modulo 2: Attacchi su Piattaforme di Training Ufficiali

- Transizione verso scenari realistici: configurazione VPN e setup dell'ambiente d'attacco per piattaforme cloud-based.
- Laboratori guidati su **TryHackMe (THM)**: risoluzione di percorsi (paths) legati all'Offensive Security e al Web Hacking.
- Laboratori su **HackTheBox (HTB)**: applicazione della kill-chain completa (Reconnaissance, Initial Access, Privilege Escalation) su macchine target (sistemi operativi Linux e Windows).

FASE II: Sicurezza Infrastrutturale e di Rete

Modulo 3: Manipolazione del Traffico (Layer 2 e Layer 3)

- Teoria e debolezze dei protocolli di rete locale (ARP, DNS, DHCP).
- **Layer 2 Attacks:** Esecuzione di attacchi di **ARP Spoofing / ARP Poisoning** per intercettare e manipolare il traffico LAN.
- **Layer 3 Attacks:** Implementazione di **DNS Spoofing** per il reindirizzamento fraudolento delle richieste di risoluzione dei nomi a scopo di phishing o credential harvesting.
- Analisi del traffico intercettato tramite analizzatori di protocollo (Wireshark/tcpdump).

Modulo 4: Laboratorio su Dispositivi di Rete Fisici (Cisco)

- Sicurezza degli apparati di rete: interazione con router e switch Cisco fisici.
- Analisi delle vulnerabilità di configurazione: debolezze in protocolli di routing, SNMP, Telnet e password management (Type 7 / Type 5).
- Attacchi diretti agli switch: MAC Flooding, DHCP Starvation.
- Best practice per la messa in sicurezza degli apparati (Hardening e mitigazioni).

FASE III: Sicurezza del Software e Binary Exploitation

Modulo 5: Fondamenti di Architettura e Memoria

- Introduzione alla sicurezza a basso livello (Low-Level Security) e al processo di compilazione di un binario.
- Architettura dei processori **x86**: registri della CPU (EIP, ESP, EBP, ecc.), struttura della memoria (Stack, Heap, Text, Data).
- Introduzione ai debugger (es. GDB per Linux) e reverse engineering di base per l'analisi del flusso di esecuzione.

Modulo 6: Buffer Overflow su x86 (Pratica di Exploitation)

- Teoria della corruzione della memoria: come e perché avviene un **Stack-based Buffer Overflow**.
- Processo di sviluppo dell'exploit (Exploit Dev):
- Panoramica sulle moderne contromisure a livello di sistema operativo: ASLR (Address Space Layout Randomization) e DEP/NX (Data Execution Prevention).